

High value certification — trust services for complex eCommerce transactions

T Rea

The emergence of the Internet as a channel for business communications and transactions has created a market for a wide range of new products and services, but a number of barriers to full-scale exploitation remain. Chief among these barriers are the Internet's general lack of integrity and the difficulty of establishing trust between trading parties. The trust services now being offered by BT help to address the Internet's lack of integrity, and current research and development work is focused on evolving these services to allow trading parties to establish trust. High value certification services will provide mechanisms which allow users to go beyond proving who they are and enable them to prove relevant aspects of their character and ability. This paper outlines the ideas behind high value certification and presents an analysis of some of the key issues.

1. Introduction

Commerce is based upon a collection of facilitating processes which have been created and implemented over a long period of time to encourage co-operation between buying and selling parties. At the very basic level, the individual parties in a commercial transaction rely on interpersonal mechanisms to evaluate the other party and to form an opinion of the trustworthiness of that party. On a broader level, a facilitating infrastructure consisting of accepted procedures, common terms, legal frameworks and financial intermediaries has evolved to ensure integrity. The transactions we take for granted today are actually based upon a complex collection of precedents and processes which have evolved over many years.

Over the past decade, the emergence of open, ubiquitous communication networks has created the foundation for electronic commerce. Electronic commerce (eCommerce) promises to revolutionise the way we conduct business through increasingly sophisticated automation of core tasks and through extending the reach of every party with negligible additional costs. Many groups have been quick to grasp the potential benefits of eCommerce and have, quite rightly, made efforts to develop systems which allow businesses and consumers to transact business on-line. Despite the enthusiasm with which the Internet has been accepted as a commercial medium, however, it is generally lacking in commercial integrity. Individual parties have no recourse to their established interpersonal mechanisms for evaluating one another and the facilitating infrastructure of physical commerce is in many ways inadequate or non-applicable.

Some of the broader issues associated with trust in the context of eCommerce have been discussed elsewhere [1, 2]. To begin to address these issues, a collection of services based on the use of cryptography, and known as Trust Services, has been developed [3]. These services allow users to establish their identity on-line, to communicate confidentially, to ensure the integrity of their communications and to resort to non-repudiation mechanisms to verify or prove message transactions. BT has recently entered the market as a provider of trust services with its Trustwise product line [4]. While these services are critical to the creation of a trustworthy environment, they are only the basis for a rich set of trust-related products and services which must evolve in order to facilitate the broader vision of eCommerce. The opportunities for BT as a provider of trust services and as a trusted third party in eCommerce are immense.

The overall goal of this work is to provide an insight into the ideas behind the evolution of the 'core' Trust Services provided by Trustwise towards the next phase which we term 'high value certification'. The initial ideas behind high value certification are defined, potential types of certificates are identified and the constraints of verification and control are examined before going on to outline potential mechanisms. Brief consideration is given to the facilitating infrastructure which must be in place.

The remainder of this discussion assumes that the reader is familiar with the workings of basic trust services — see, for example, Skevington and Hart [3].

2. High value certificates

The term ‘high value certification’ is used to describe a collection of certification-based services which extend the functionality of core Trust Services such as those offered by BT Trustwise. These core services provide the basis for establishing an on-line identity, but an identity is more than a name — it is also a collection of associated attributes. High value certificates allow users to go beyond proving who they are and allows them to prove aspects of their character and ability.

2.1 The notion of a certificate

Before discussing how high value certification might be achieved, it is useful to start with an overview of what a certificate actually is. A certificate is a structured digital document which contains specific items of information including the identity of the issuer, the identity of the certificate subject, the public key of the certificate subject as well as various items of information about how the certificate was created. The information about the certificate and the certificate subject is bound to the public key by the signature of the issuing authority. Figure 1 shows a representation of a certificate and the information it contains. The full specification is given in ITU-T X.509 [5].

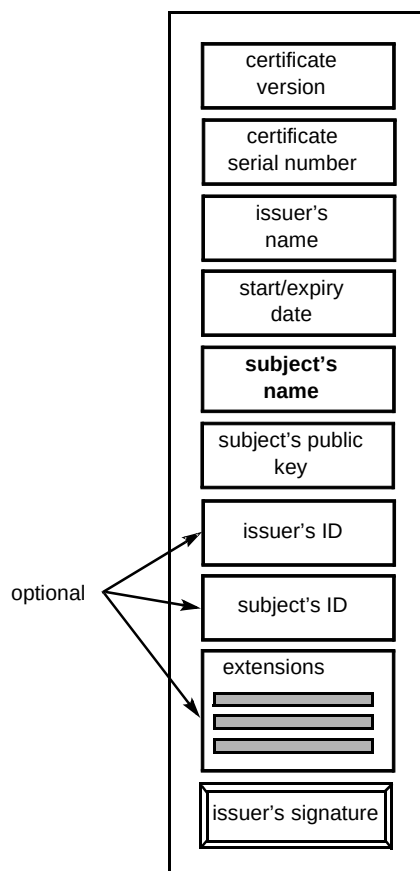


Fig 1 An illustration of an X.509 certificate.

The critical component of a certificate as shown in Fig 1 is the subject. The standard certificate enables the association of a key with a user, but does not, in general, say anything about how the certificate can be used. Version 3 of the X.509 certificate contains an array of extension fields which allow further information to be appended to the certificate. Some standard extensions have been defined, and it is possible for new extensions to be created [6].

One of the standard extensions in the X.509 V3 certificates is a policy field which can accommodate a certificate policy statement. The policy statement can, in principle, provide guidelines on how the certificate should be used, but in practice there are no clear implementations of this and there are no generally accepted formats for presenting certificate policies or for validating them. It is currently common practice to issue ‘classes’ of certificates, with each class describing different levels of information validation. A class 1 certificate from BT Trustwise, for example, is issued on the basis of having validated an e-mail address while a class 2 certificate is issued only after the issuing authority has verified the existence of the subject from third-party information (e.g. an electoral roll). Classes of certificate, however, have nothing to do with governing usage.

In the context of the established standards for certification, high value certification can be defined as the process of associating information about a certificate subject with a certificate. As will be shown, high value certification also covers the process of verifying the truth of the attributes associated with the certificate subject as well as governing and controlling the usage of the attributes.

2.2 A typology of high value certificates

As described above, a standard certificate allows a user to say, for example, ‘I am Mr X’ while a high value certificate allows a user to say, for example, ‘I am Mr X and I am authorised to act on behalf of Company Y as the Director of Finance’. In general, high value certificates will allow users to go beyond proving who they are to say something about themselves.

Simple examples of attributes for Mr X, the certificate subject, include:

- Mr X is a citizen of the United Kingdom,
- Mr X can drive a car,
- Mr X is a Chartered Accountant,
- Mr X has a degree in business,
- Mr X has a bank balance of £500,
- Mr X is authorised to use Company Y’s financial accounting system,

- Mr X can be trusted in financial transactions up to the amount of £500,
- Mr X can trade on the stock market and incur an overall liability of £5000,
- Mr X can enter into transaction Z and will be underwritten to the value of £10 000.

If the subject of certificates were extended to include companies, the following might be available:

- Company Y has been in operation since 1965,
- Company Y is a going concern (i.e. is not under threat of liquidation/bankruptcy),
- Company Y is ISO9001 registered,
- Company Y made an audited profit of £5m on turnover of £12m in 1998,
- Company Y is rated AA (i.e. the company's capacity to meet financial commitment is very strong) by Standard and Poor's credit rating system.

The list of attributes can clearly be extensive for individuals and for companies. An analysis of the examples above reveals a number of categories of high value certificates. In general, there are 'attributes' which represent specific facts about a subject, there are 'authorisations' which indicate that a subject is allowed to do specific things and there are 'guarantees' which indicate that some entity has accepted liability for a subject in some way. A further decomposition includes:

- permanent attributes — those retained permanently (e.g. a degree),
- dependent attributes — those normally retained long-term unless specifically revoked by the granting party (e.g. a licence to practice medicine),
- period attributes — those subject to validation on a periodic basis (e.g. membership of a professional body subject to a yearly charge),
- temporal attributes — those strongly time-dependent (e.g. the balance of a bank account which may only be valid for the length of time it takes the owner to commit to another transaction),
- general authorisation — permission for an undefined level of usage of some resource (e.g. authorisation to use a computing resource),
- specific authorisation — permission for finite usage of some resource (e.g. permission to use a service five times),

- general guarantee — a general insurance by some third party (e.g. a guarantee indicating that a third party will accept liability for the subject's transactions up to a certain amount, similar to a cheque guarantee card),
- specific guarantee — a guarantee by some third party for a specific type of activity (e.g. a guarantee indicating that a third party will accept liability for the subject's financial transactions within a share-dealing environment with specified limits).

3. High value certification

The first stage of creating high value certification services involves understanding how to verify attributes, authorisations and guarantees. The second stage involves defining mechanisms which facilitate the association of this information with an ID certificate, and the third stage involves controlling usage.

3.1 Constraints of verification and control

The verification of the attributes, authorisations or guarantees to be associated with the subject of a certificate presents a number of significant challenges. Likewise, there are many different types of control requirements for the various applications. An initial analysis of the list of certificate types above makes it clear that no single entity could possibly act as a verifier of all of these things and that no one control mechanism could satisfy the requirements of every certificate type. The real challenge, then, is to define a system which allows a trusted third party to work with other parties to obtain the necessary verification and to assert the necessary control. The requirements of the verification and control process for different types of certificates will have a significant impact on the mechanisms used for issuance and control.

3.1.1 Types of verification

The types of verification include the following.

- Burden of proof
Attribute holders are required to present the high value certification authority with proof that they possess the attribute. This is relevant for permanent attributes which do not normally change and which are usually backed by some physical certificate. Thus, when a user applies for an identity certificate, proof of citizenship, a driver's licence and a degree certificate may also be provided so that these attributes can be added to the user's profile.
- Third party proof (physical channel)
The attribute holder can assert their possession of the attribute, but verification requires the clearance of some outside party and the only channel of

communication is physical. This may apply to dependent attributes, period attributes, temporal attributes, the authorisations, and the guarantees where the relevant confirming body provides only physical channels for verification. There are obvious implications for response times if the applicant must wait for verification. Users, for example, may require a certificate to prove that they are licensed to practice medicine in the UK so that they can provide medical advice on-line; they apply for the high value certificate and have to wait for the high value certification authority to obtain verification from the British Medical Association before the certificate is issued.

- Third party proof (on-line channel)

As with the third party proof with a physical channel, the attribute holder asserts their possession of the attribute and verification is made by referring to the relevant authority through an on-line channel. The truth of the attribute can potentially be verified immediately and the certificate could be issued in real time.

In the cases of the period attributes, temporal attributes, specific authorisations and specific guarantees, the certifying party must not only verify the truth of the applicant's request, but must also obtain the information required for control. The verification of these things is subject to certain limitations regarding the usage of the certification.

3.1.2 Types of control

Control requirements include the following.

- Time based (application independent)

An assertion is verified to be true within some arbitrary time-frame which is defined to provide a regular review of the user's status and/or to create regular chargeable events. In the case of certificates for period attributes, for example, the verifying authority may wish to limit the lifetime of the certificate to one year so that the user's status can be reaffirmed on a regular basis and so that chargeable events can be created.

- Time based (application-dependent)

An assertion is verified to be true within some specific time-frame which is defined according to the span of some contract or the lifetime of the attribute, authorisation or guarantee in question. A temporal attribute, for example, may be verified with a well-defined lifetime which reflects the time span over which the attribute is likely to be true. A certificate stating that the subject's bank account contains more than £100 may be granted subject to the condition that the certificate only be used for a period of 3 days.

- Usage based (limited usage events)

An assertion is verified and a certificate issued with the condition that the user only be allowed to prove their possession of the attribute a certain number of times. Thus, a specific authorisation or a specific guarantee may be verified with the condition that the user only be allowed to assert their possession of the authorisation or guarantee a specified number of times.

- Usage based (limited application)

An assertion is verified and a certificate issued with strict limitation on the applications with which the certificate can be used. A specific guarantee of a user's ability to enter into transactions up to the value of £1000, for example, may be verified for use within a specified trading environment and will be considered invalid if it is used outside of that domain.

- Event control

For all certificates, the issuer must be able to revoke the certificate if some event causes it to be invalidated. If, for example, a guarantee certificate is compromised and can be used by an unauthorised party, the certificate issuer must be able to revoke or somehow invalidate that certificate.

- Liability control

An assertion may be verified subject to the specification of limited liability by the verifying authority. In the case of a general authorisation, for example, a verifying authority may permit the certification of the user's authority for the application in question, but may wish to renounce all liability associated with this verification.

The creation and incorporation of a certificate policy is key to the issue of certificate control. Certificate policies will include guidelines on certificate usage, statements of limited liability where relevant, and will outline the verification procedure which a relying party must complete before a certificate is considered to be valid. The policy will typically be created as a separate file and assigned a reference number before being placed into an on-line repository. The reference number will then be incorporated into the certificate in an extension field. The idea of incorporation by reference and the legal implications of this are discussed further in section 3.3.

The different types of high value certificate and the relationship between their requirements for verification and control are illustrated in Fig 2.

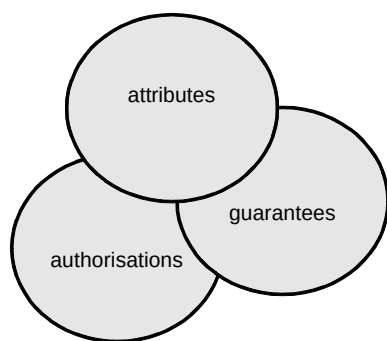


Fig 2 Types of high value certificate.

3.2 Mechanisms

The foregoing discussion presumed one central point of certification and one certifying body. It is clear from the analysis, however, that many of the situations would be made significantly simpler if verification and issuance could be managed by the same party. This section first outlines the basic mechanisms for associating attributes with users and then considers the issue of distributing the functionality between an issuer and facilitator.

The basis of a high value certificate will be the subject's ID certificate. High value certification mechanisms will act to either enhance the ID certificate or will create a new data structure which is somehow associated with the ID certificate.

3.2.1 X.509 with extensions

A digital ID certificate is based upon the X.509 standard and includes an array of extensions which can be defined by the issuing party. In principle, an attribute/authorisation or guarantee could be described in an extension field, but there are problems associated with the amount of information which can actually be inserted into a certificate. In practice, complex attributes would be described in a separate file and this file would be incorporated by reference into the certificate in the same way as the certificate policy described above.

The static nature of the X.509 certificates make them unsuitable for some categories of high value certificate. A user may have a digital ID with no attributes to enable basic authentication and may have an enhanced digital ID with a number of static attributes included in the extension fields. This mechanism is suitable for permanent and dependent attributes. It is also suitable for period and temporal attributes where the time period of the attribute is greater than the lifetime of the subject's digital ID certificate. Theoretically, this mechanism could be applied to general authorisations and general guarantees, but it is likely that these things will require more careful control.

3.2.2 X.509 with directory control

Instead of incorporating the attribute information directly into a certificate, the high value certification service

can be based upon the maintenance of an on-line directory which contains information on a user's attributes which can be directly associated with a specific digital ID. When users wish to add more attributes to their profiles, they apply to the service operator and, after the relevant verification, the attribute, authorisation or guarantee is added to their profile. This approach offers a convenient method of control for the service operator — if an attribute ceases to be true, it is simply removed from the profile.

There are a number of shortcomings to this method, however. In this model, a transaction involves a certificate subject asserting their possession of an attribute to a potential relying party. This relying party must now go to the service operator and request verification. In the case of a user with a general guarantee for transactions up to £50, each time the user enters into a transaction, the relying party must go to the directory to check if the user's claim on the guarantee is still valid. If the system is to have the level of integrity required to support high value certificates, the directory should be trusted. The implication of this is that each validation response from the directory would have to be signed and time-stamped by the directory operator thus adding significant overhead to the operation of the system.

The directory approach does provide a solution for general and specific authorisations. The use of a directory may be the optimal solution if the directory is integrated with or easily accessible from the resource which is the subject of the authorisation.

3.2.3 Attribute certificate

The idea of attribute certificates has been outlined in a recent draft standard from the Internet Engineering Task Force [7]. The attribute certificate is similar in structure to an X.509 certificate, but it contains no public key — it is essentially linked to a digital ID and contains specific references to attributes of the holder of the digital ID. Because the attribute certificate does not contain any public key information, it can be created by any party capable of signing the data structure.

Attribute certificates may be particularly suitable for temporal attributes, general and specific authorisations as well as general and specific guarantees. In these cases, a user can apply for an attribute certificate from the relevant verifying body and receive an electronic certificate which can be presented to a relying party for verification. In this case, verification involves using the public key of the verifying authority to validate the attribute certificate.

The control of attribute certificates, however, presents a number of challenges. The certificate revocation list method used to control normal digital IDs will not be adequate for applications where the issuer wishes to provide the user with limited use of, for example, an authorisation or guarantee. Also, the fact that an attribute certificate contains no public key information means that it must be used in

conjunction with a digital ID so that a relying party must now validate two certificates.

Mapping these three potential mechanisms on to the types of high value certificate described above results in something like the situation illustrated in Fig 3.

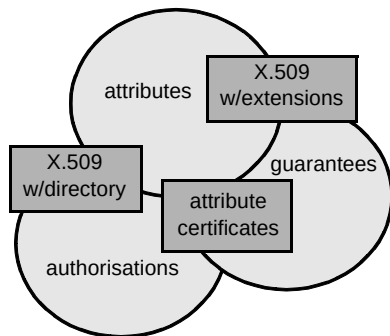


Fig 3 Mechanisms mapped on to types of certificates.

3.3 Facilitating infrastructure

To facilitate high value certification services, supporting technical and legal infrastructure must be put into place. The mechanisms for issuing and controlling high value certificates can, for the most part, be created by extending and enhancing existing technology, but new approaches to establishing legal reliability and assessing risk must be developed. The following sections provide an insight into some of the legal issues.

3.3.1 Incorporation by reference — the ETERMS repository

The analysis of high value certificates shows a clear requirement for the incorporation of a policy into a certificate. A certificate policy would outline the conditions under which the certificate was issued, provide guidelines for usage of a certificate, stipulate limitation of usage, outline the verification procedure which must be followed before the certificate can be relied upon, and could also provide a statement of limited liability on the part of the issuing party. The policy will be given a reference number and this reference number will be included in the certificate. The net effect is that the policy governing the usage of the certificate will be incorporated by reference into the certificate.

The issue of incorporation by reference carries with it certain legal implications. While many countries have established precedents for physical transactions which allow the creators of contracts to incorporate their terms and conditions by referring to them in the contract, the issue of incorporation by reference in electronic transactions has not been fully addressed. There are a number of countries where incorporation by reference is illegal even for physical transactions so that further complexity is added to the situation. In all cases, the issue of incorporation by reference is closely linked to the issue of the accessibility of

the incorporated materials. The ETERMS (electronic terms) repository addresses the issue of accessibility.

A model law currently under review by UNCITRAL [8] states:

‘Unless otherwise agreed between the parties, a data message is regarded as an incorporated part of another data message, if such incorporation is intended by the originator and that other data message indicates a procedure whereby the incorporated data message can be accessed in a reasonable and timely manner.’

The primary issues are (a) ensuring that the relying party is aware that there is a policy which has been incorporated by reference, and (b) providing the relying party with access to the incorporated data. The process of accepting a high value certificate must require the relying party to retrieve the policy from a trusted repository and accept its terms and conditions. The trusted repository, in order to establish legal reliability, must have a very high degree of accessibility, must have established processes which control the submission and retrieval of information and facilities to audit submission and retrieval.

BT is involved in a project with the International Chambers of Commerce (ICC) and a number of other companies to create a trusted repository which would fulfil these conditions. The ETERMS project is drawing upon the legal expertise of many of the law firms associated with the ICC as well as a range of technical and service management expertise. An experimental repository has been made available to the legal community for comment.

3.3.2 Data protection and consumer privacy

In addition to establishing facilitating legislation as described above, it is necessary to actively prevent the creation of legislative barriers and push to remove existing barriers. One of the key areas of concern at present is in the area of data protection and privacy. These issues have attracted a significant amount of attention and there are a number of initiatives which are targeted at establishing codes of practice or legal guidelines to protect the privacy of the individual consumer.

The issue of privacy has become even more contentious due to the emergence of the Internet as a medium for commerce, for entertainment and for communications. It is now possible, with sufficient resource, to assemble a sophisticated profile of an individual. In some ways, this benefits the consumer because it facilitates mass-customisation and customised service. Despite the benefits, however, there is a clear boundary beyond which assembling, analysing, exploiting and selling information about an individual is a violation of that individual's rights. The global nature of the Internet and the uneven regulatory environment combined with the unprecedented degree of

connectivity also mean that once a profile of an individual is assembled, the damage is very difficult to undo.

Legal frameworks which provide protection to consumers are essential, but it is important that this legislation does not prevent the development of services such as high value certification which have the potential of enabling a vast range of sophisticated eCommerce applications. There is a clear role for technology and service companies in this area to work in partnership with governmental bodies to achieve the right balance between consumer protection and privacy on one hand and effective exploitation of new technologies on the other. BT has taken an active role in providing support and consultancy to the UK government and the European Commission.

4. Conclusions

This paper has presented an overview of the ideas behind high value certification and an analysis of some of the issues. There are, as yet, no clear solutions which meet the needs of every potential application, but there are a number of different implementations which can be used together to offer a range of high value certificates. The key challenges for a trusted third party are to create an infrastructure which is flexible enough to allow the dynamic creation of new types of certificate as new applications emerge, and to create a facility which will enable verifying authorities to either validate a user's claim to an attribute, authorisation or guarantee or to go beyond validation to actually create and issue an attribute certificate under their own authority or operate a directory of attribute information.

Acknowledgements

The author would like to acknowledge the help of Andrew Wheelhouse in researching aspects of this paper.

References

- 1 Rea T and Skevington P J: 'Engendering trust in electronic commerce', *British Telecommunications Eng J*, **17**, p 150 (1998).
- 2 Rea T: 'Trusted third parties', in Castelfranchi C and Tan Y H (Eds): 'Deception, fraud and trust in agent societies', Kluwer Academic Publishers, in publication.
- 3 Skevington P J and Hart T: 'Trusted third parties in electronic commerce', *BT Technol J*, **15**, No 2, pp 39—44 (April, 1997).
- 4 Cross B A: 'BT Trustwise — enabling eCommerce through trust', *BT Technol J*, **17**, No 3, pp 44—49 (July 1999).
- 5 http://www.itu.int/itudoc/itu-t/rec/x/x500up/x509_27505.html
- 6 Ford W and Baum M: 'Secure electronic commerce', Prentice Hall (1997).
- 7 Farrell S: 'draft-ietf-tls-ac509prof-00.txt', from the Transport Layer Security Working Group — <http://www.pca.dfn.de/eng/team/ske/drafts/draft-ietf-tls-ac509.prof-00.txt> (August 1998).
- 8 <http://www.verisign.com/Eterms/Draft.html>



Tim Rea began working in eCommerce in 1996 and has been involved in a number of projects relating to the development and evolution of trust services. His work has included a broad analysis of the nature of trust and of the roles that trust plays in electronic commerce and electronic transactions, and he has used this work to fuel the evolution of BT's portfolio of trust services. Other current work includes general eCommerce analysis and consultancy, a collaborative research project with NTT and a collaborative project with the International Chambers of Commerce. He holds a BEng from the

University of Sheffield, an MSc from the University of London and is in the process of completing an MBA at London Business School.